SIMATS ENGINEERING

Saveetha Institute of Medical And Technical Sciences

ASSESSMENT TOOL 3

Scenario-Based Assessment

Report Analysis

Name	B Akshaya
Register Number	192424336
Date	22.10.2026
Course Code	ITA1420
Course Name	Ethical Hacking

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks. (BT4)

Assessment Tool Weightage: 30% | **Duration:** 90 min | **Total Marks:** 50

Code of Conduct:

I B Akshaya (192424336) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: *Akshaya*

1. Identify the Assessment Objective

1.1 Scenario and Purpose

A cybersecurity consultant is assigned to assess **ABC Technologies** from the outside, using only public information and without sending traffic to the company's servers. The assessment also covers an authorised DNS test and a social engineering scenario. The overall goal is to show how footprinting, DNS analysis and human-targeted attacks reveal weaknesses before a real attacker finds them (CO2, BT4).

1.2 Tasks and Objectives

Table 1: Assessment tasks mapped to objectives

Q	Topic	Objective	Marks
Q1	Competitive intelligence footprinting	Passively identify domain registration details, employee e-mails, technology stack and exposed subdomains, and explain each tool's role	15
Q2	DNS zone transfers	Verify whether zone transfers are allowed and explain how the records expose internal hosts, mail servers and subdomains	15
Q3	Social engineering	Identify the attack in a fake IT credential-verification e-mail and apply employee countermeasures	20

1.3 Scope, Assumptions and Ethics

- **Passive only (Q1):** public registries, search engines, certificate logs and third-party databases are used; no scanning or probing of ABC Technologies' servers.
- **Authorised testing (Q2):** the zone-transfer check is performed only because the penetration test is authorised in writing.
- **Safe handling (Q3):** the phishing e-mail is analysed, not clicked; no credentials are entered.
- The domain **abctechnologies.example** is a placeholder for the company's assigned lab domain; sample outputs show the format of real results.

1.4 Assessment Workflow



Figure 1: Six-step workflow followed in this report

The workflow follows the sample writing steps: objective, tool selection, collection and analysis, identification of key details, the role of each tool in competitive intelligence, and findings.

2. Select Suitable Footprinting Tools

2.1 Selection Criteria

Because the brief forbids direct interaction with company servers, each tool was chosen for three reasons: it relies on **public or third-party data**, it covers a required data item, and it is available in Kali Linux or as a free online service. Tools that connect to the target (port scanners, browser plug-ins that load the site) were avoided in Q1.

2.2 Tools Selected

Table 2: Tool selection for Q1 and Q2

Tool	Type	Data obtained	Interaction with target?
WHOIS	Registry lookup	Domain registration details	No (queries the registry)
theHarvester	OSINT collector	E-mails, subdomains, hosts, IPs	No (queries public sources)
crt.sh / DNSdumpster	Certificate and passive DNS	Publicly exposed subdomains	No (third-party database)
BuiltWith / Netcraft	Online profiler	Technology stack	No (stored scan data)
Google dorks / LinkedIn	Search engines	Staff names, documents, roles	No
dig (AXFR)	DNS client	Zone records (Q2)	Yes, with authorisation

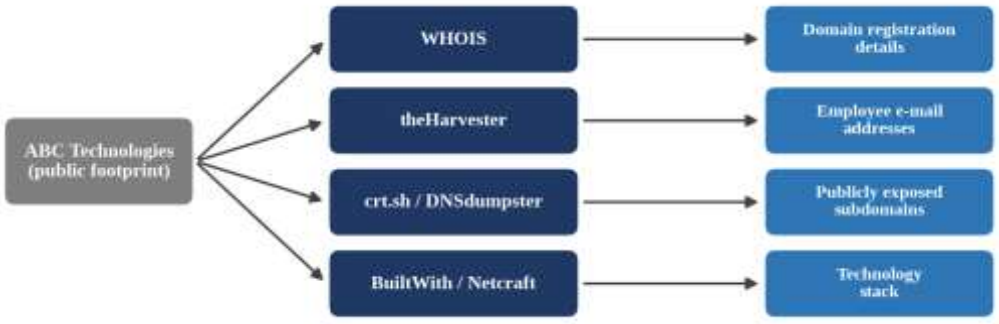


Figure 2: Mapping of tools to the intelligence items required in Q1

2.3 Why Passive Footprinting First

Passive footprinting leaves no trace in the target's logs, so it cannot alert the defenders and it is legally low-risk. It also gives the consultant a precise picture of what any outsider can learn, which is the starting point of both competitive intelligence and a real attack.

Table 3: Passive versus active footprinting

Aspect	Passive	Active
Contact with target	None	Direct packets or requests
Detectability	Not detectable	May be logged or blocked
Examples	WHOIS, theHarvester, crt.sh	Nmap, dig AXFR, banner grabbing
Use in this report	Q1	Q2 (authorised)

3. Collect and Analyze Publicly Available Information

3.1 Q1: Passive Collection Commands

Table 4: Commands and online lookups used

Step	Command / source	Purpose
1	whois abctechnologies.example	Registrar, dates, name servers, registrant
2	theHarvester -d abctechnologies.example -b crtsh,hackertarget,rapiddns,duckduckgo -f abc_osint	E-mails, hosts and IPs; save XML/JSON
3	crt.sh query: %.abctechnologies.example	Subdomains from SSL certificate logs
4	BuiltWith / Netcraft site report	Web server, CMS, scripts, hosting, mail provider
5	Google dork: site: and filetype:	Public documents, staff names, job posts

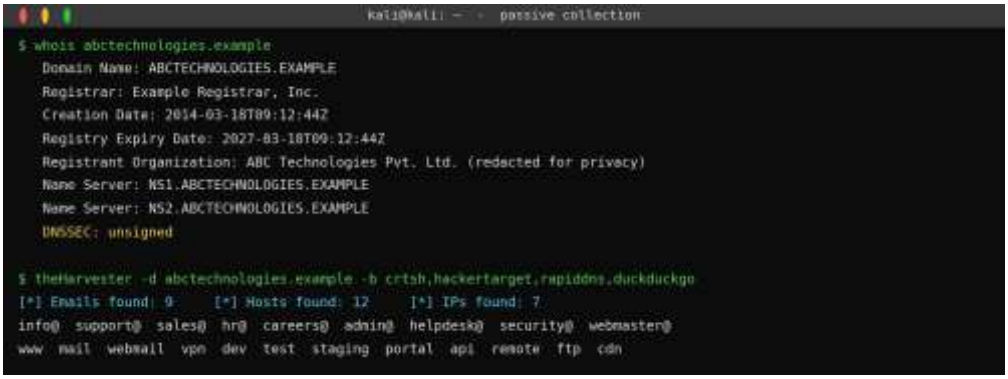


Figure 3: Sample output of WHOIS and theHarvester

Analysis. WHOIS gave ownership and name-server data, theHarvester returned 9 e-mails, 12 hosts and 7 IP addresses, and certificate logs confirmed the same subdomains. Using several sources and cross-checking results improves accuracy.

3.2 Q2: Verifying DNS Zone Transfers

DNS servers copy a zone to secondary servers using AXFR over TCP port 53. If the primary server answers any requester, the whole zone is exposed. The analyst first finds the name servers and then tests each one.



Figure 4: Zone-transfer verification workflow

Table 5: Commands to verify zone transfer

Command	Purpose
dig NS abctechnologies.example +short	List authoritative name servers
dig axfr abctechnologies.example @ns1.abctechnologies.example	Request a full zone transfer from each name server
host -t axfr abctechnologies.example ns1.abctechnologies.example	Alternative test using host
dnsrecon -d abctechnologies.example -t axfr	Automated test of all name servers

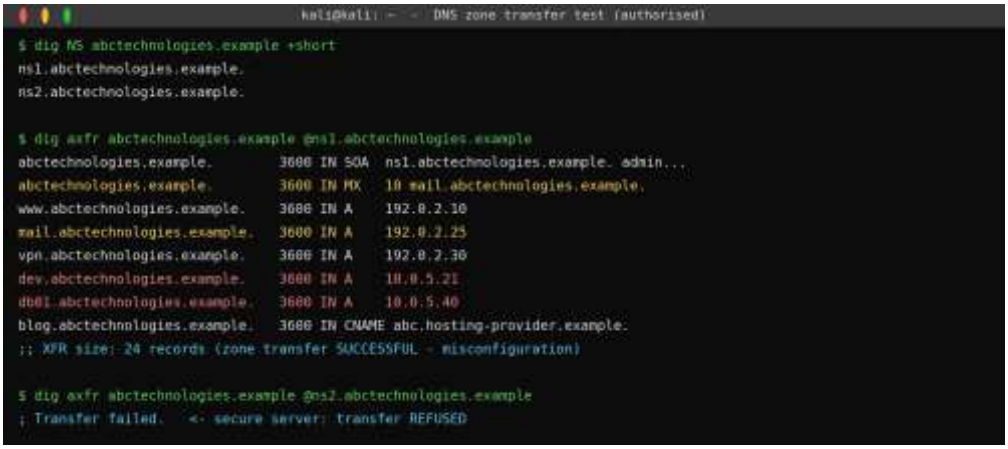


Figure 5: Sample result: ns1 allows AXFR, ns2 refuses

A transfer returning many records proves that **zone transfers are permitted** to unauthorised hosts; a reply of "Transfer failed" or REFUSED means the server is correctly restricted.

Table 5A: DNS record types seen in a zone file

Record	Meaning	Reconnaissance value
A / AAAA	Hostname to IPv4 / IPv6 address	Server locations and internal ranges
MX	Mail servers of the domain	E-mail infrastructure and phishing targets
NS	Authoritative name servers	DNS topology
CNAME	Alias to another name	Cloud and third-party services
TXT	SPF, DKIM and verification text	Mail policy and SaaS providers
PTR / SRV	Reverse lookup and service location	Internal service discovery

3.3 Q3: Analysis of the Suspicious E-mail

Employees receive an e-mail that claims to come from the IT department and asks them to verify login credentials through a link because of an “urgent security update”. The message was analysed without clicking the link.

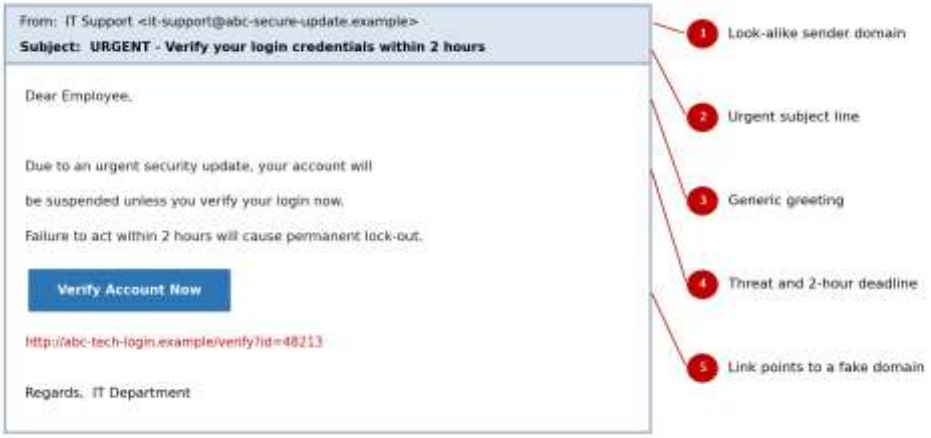


Figure 6: Sample phishing e-mail with indicators marked

Table 6: Red flags found in the e-mail

No.	Indicator	Why it is suspicious
1	Sender domain abc-secure-update.example	Not the company's real domain; look-alike address
2	Subject marked URGENT	Creates pressure so users act before thinking
3	Generic greeting “Dear Employee”	Real IT staff normally use names and ticket numbers
4	Threat of suspension in 2 hours	Fear and deadline are classic manipulation
5	Link to abc-tech-login.example	Link domain differs from the company login domain

Table 6A: Psychological triggers used in the e-mail

Trigger	How the e-mail uses it	Defensive habit
Authority	Pretends to come from the IT department	Verify unusual requests through a separate channel
Urgency	“Within 2 hours” deadline	Pause; urgency is a warning sign
Fear	Threat of account suspension	Contact the helpdesk directly
Familiarity	Company style and wording copied	Check the sender domain and URL carefully

Conclusion of analysis. The combination of a spoofed sender, an urgent threat and a credential request matches the pattern of a phishing attack. Recognising these indicators before clicking is the employee's first line of defence.

4. Identify Domain Details, Email Addresses, Technology Stack, and Subdomains

4.1 Domain Registration Details

Table 7: Domain registration findings (sample)

Field	Finding	Intelligence value
Registrar	Example Registrar, Inc.	Shows where account takeover or domain hijack could occur
Created / expires	2014-03-18 / 2027-03-18	Company age; expiry date is a renewal-lapse risk
Registrant	ABC Technologies Pvt. Ltd. (privacy redacted)	Confirms ownership; privacy limits staff data leakage
Name servers	ns1 and ns2 under the company domain	Self-hosted DNS; target for Q2 test
DNSSEC	Unsigned	DNS responses can be forged more easily

4.2 Employee E-mail Addresses

Table 8: E-mail addresses found by role (sample, 9 addresses)

Category	Mailbox patterns	Risk
General / Admin	info@, admin@	Spoofing and mass phishing
Customer-facing	support@, sales@	Receives external attachments and links
HR	hr@, careers@	Opens CV files; holds personal data
Technical	helpdesk@, security@, webmaster@	Privileged staff; prime pretext and spear-phishing target

The role@domain pattern also suggests personal formats such as first.last@domain, which an attacker can use to guess more addresses.

4.3 Technology Stack

Table 9: Technologies identified from BuiltWith / Netcraft (sample)

Layer	Technology	Competitive and security relevance
Web server	Nginx	Known version may map to public CVEs
CMS / language	WordPress, PHP	Plug-in flaws are a common entry point
Hosting / CDN	AWS, Cloudflare	Reveals cloud strategy and DDoS protection
E-mail provider	Microsoft 365	Shapes realistic phishing templates
Analytics / scripts	Google Analytics, jQuery	Third-party scripts widen the attack surface

Analysis. The stack tells a competitor how the company builds and hosts its services and tells an attacker which known vulnerabilities and phishing themes (for example Microsoft 365 sign-in pages) to try first. None of this required contact with ABC Technologies' servers.

4.4 Publicly Exposed Subdomains

Table 10: Subdomains identified (sample, 12)

Subdomain	Category	Observation
www, cdn, blog	Public web	Expected public presence
mail, webmail	Mail	Login pages attractive for cloning
vpn, remote	Remote access	Entry point if credentials are stolen
dev, test, staging	Development	Often unpatched; may hold real data
portal, api, ftp	Applications	Reveals services and possible weak endpoints

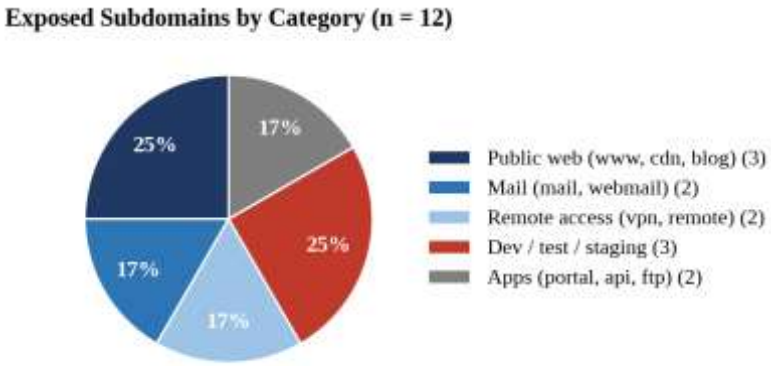


Figure 7: Share of exposed subdomains by category

4.5 Q2: How Zone-Transfer Records Reveal the Network

Table 11: Records retrieved and how an attacker uses them

Record	Example from Figure 5	Information gained
A / AAAA	dev → 10.0.5.21, db01 → 10.0.5.40	**Internal hosts:** private addresses show the internal layout and database servers
MX	mail → 192.0.2.25	**Mail servers:** targets for phishing, spoofing and relay tests
CNAME	blog → hosting provider	**Subdomains and third parties:** possible subdomain takeover
NS / SOA	ns1, ns2, admin contact	DNS topology and administrator contact
TXT	SPF and verification tokens	Mail policy and SaaS providers in use

With these records the attacker skips guessing: the list of hosts becomes a ready scan target list, weak dev and test systems are attacked first, and phishing e-mails can use real server names to look genuine.

4.6 Q3: Type of Social Engineering Attack

The e-mail is a **phishing attack** (credential harvesting). It impersonates the IT department, uses authority and urgency, and sends victims to a fake login page. Because it is sent to many employees at once it is bulk phishing; if it used staff names and real systems it would be **spear-phishing**.

5. Explain the Role of Each Tool in Competitive Intelligence

5.1 Role of Each Tool (Q1 and Q2)

Table 12: Contribution of each tool to competitive intelligence

Tool	Role in competitive intelligence	Example insight
WHOIS	Reveals ownership, registrar and domain age; shows brand portfolio when many domains share a registrant	Company has operated online since 2014
theHarvester	Maps people and hosts; shows departments and how the company presents contacts	Dedicated HR, support and security mailboxes exist
crt.sh / DNSdumpster	Lists products, portals and partner services from certificates and DNS	Customer portal, API and staging environments in use
BuiltWith / Netcraft	Shows technology choices, vendors and hosting, which hint at budget and strategy	WordPress on AWS with Microsoft 365 mail
Google dorks / LinkedIn	Finds public documents, job ads and team structure	Hiring pattern reveals growth areas
dig AXFR	Gives a full blueprint of hosts, mail and internal ranges (if misconfigured)	Internal dev and database servers identified

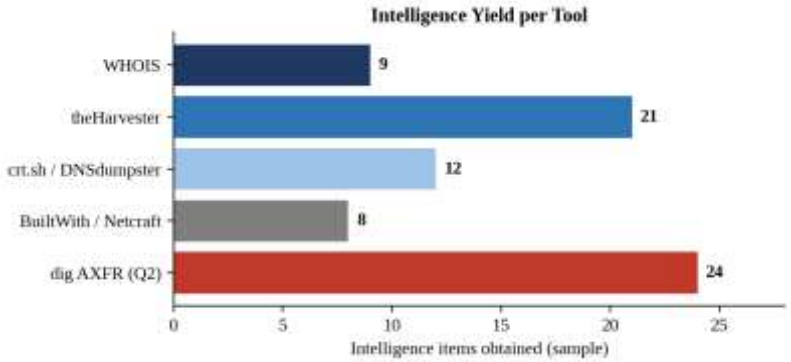


Figure 8: Intelligence items obtained from each tool (sample)

Passive tools give broad, safe coverage; the DNS test gives the highest yield but only when the server is misconfigured. Together they let a competitor or attacker learn the company's technology, partners and structure without ever visiting its network.

5.2 Q3: Countermeasures Employees Should Apply



Figure 9: Steps an employee follows before responding to the e-mail

Table 13: Countermeasures and how they prevent credential theft

Countermeasure	What the employee does	How it prevents credential theft
Verify the sender	Check the full address and domain, not only the display name	Exposes look-alike and spoofed senders
Inspect the link	Hover to preview the URL; type the official address manually	Stops the click that leads to the fake login page
Do not enter credentials	IT never asks for passwords by e-mail	No data is typed, so nothing can be captured
Resist urgency	Pause when threatened with lock-out or deadlines	Breaks the emotional trigger the attacker relies on
Confirm out of band	Call the helpdesk on a known number or raise a ticket	Confirms whether the request is real
Report the e-mail	Use the Report Phishing button; delete it	Lets security block the sender and warn others
Use MFA and a password manager	Enable MFA; let the manager autofill only on the real site	Stolen password alone is useless; autofill fails on fake domains
If already clicked	Change the password, revoke sessions, inform IT at once	Limits the time the stolen credential is usable

5.3 Organisational Controls to Support Employees

Table 14: Preventive, detective and corrective controls

Type	Control
Preventive	SPF, DKIM and DMARC; secure e-mail gateway with URL rewriting; MFA; awareness training
Detective	Phishing simulations (for example GoPhish); log monitoring for unusual sign-ins; domain monitoring
Corrective	Incident response plan, password reset, session revocation, removal of the e-mail from all mailboxes

5.4 Securing DNS and Reducing Footprint

- Restrict zone transfers to trusted secondaries with allow-transfer, and protect them with TSIG keys.
- Use split-horizon DNS so private records (10.x.x.x) never appear in public zones; delete stale records and enable DNSSEC.
- Keep dev and test hosts off the public internet, remove staff e-mails from web pages, and enable WHOIS privacy.
- Hide version banners and patch the web stack so technology profiling gives little advantage.

6. Conclusion and Findings

6.1 Summary of Findings

Table 15: Key findings and risk rating

Area	Finding	Risk
Domain registration	Details visible; DNSSEC not enabled	Medium
E-mail addresses	Role mailboxes public; naming pattern guessable	Medium
Technology stack	Web server, CMS and cloud services identifiable	Low to Medium
Subdomains	Dev, test, VPN and mail hosts exposed	High
DNS zone transfer	ns1 allows AXFR; internal hosts disclosed	Critical
Phishing e-mail	Credential-harvesting attack by IT impersonation	High

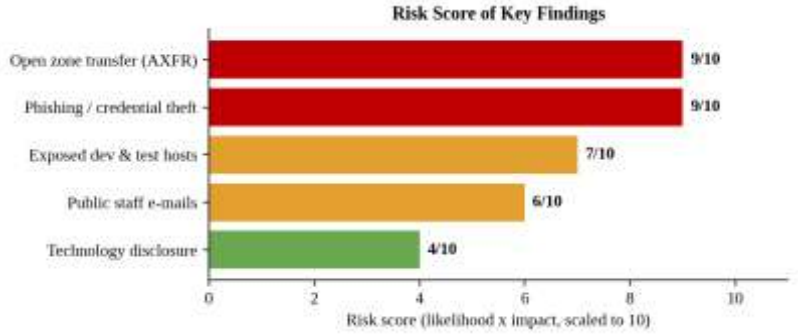


Figure 10: Risk scores of the key findings

6.2 Conclusion

The assessment shows that a great deal of competitive intelligence can be gathered without touching the company's servers: registration data, staff mailboxes, technology choices and subdomains are all public. An open zone transfer turns this into a complete network map, and a convincing phishing e-mail can turn the same knowledge into stolen credentials. The most effective defence combines technical controls (restricted AXFR, split DNS, DMARC, MFA) with alert, well-trained employees who verify before they act.

6.3 Recommendations Summary

Table 16: Priority recommendations

Priority	Action	Timeline
Immediate	Block unauthorised AXFR on all name servers; enable MFA; brief staff about the phishing e-mail	0 to 7 days
Short term	Enable TSIG, split-horizon DNS and DNSSEC; enforce DMARC; remove stale subdomains	1 to 4 weeks
Medium term	Deploy e-mail gateway and domain monitoring; phishing simulations; helpdesk call-back policy	1 to 3 months
Ongoing	Quarterly OSINT self-audit and awareness refreshers; review exposed data	Continuous

6.4 Alignment with the Course Outcome

Table 17: CO2 (BT4) elements covered

CO2 element	Evidence in this report
Competitive intelligence gathering	Sections 2 to 5.1: tools, data and their business value
DNS analysis	Section 3.2 and Section 4.5: zone-transfer test and record analysis
Attack simulation / social engineering	Sections 3.3, 4.6 and 5.2: phishing analysis and countermeasures
Identifying security risks	Section 6.1: risk-rated findings and recommendations

6.5 Declaration and References

Declaration: I certify that this report is my original work. All collection was passive or performed under authorisation, and sample outputs illustrate the format of real results.

Signature of the student: Akshaya

- theHarvester documentation (github.com/laramies/theHarvester); crt.sh certificate search; BuiltWith and Netcraft site reports.
- ISC BIND 9 Administrator Reference Manual (allow-transfer, TSIG); RFC 5936 DNS Zone Transfer Protocol (AXFR).
- NIST SP 800-115; MITRE ATT&CK T1589, T1590.002, T1596, T1566 and T1598.
- OWASP Foundation and CIS Benchmarks; Anti-Phishing Working Group awareness material.